Anexo Complementario

Análisis de Aplicaciones

TRABAJO DE FIN DE GRADO

Estudio de la Seguridad en Aplicaciones de Wearables. Creación de un Formulario Viable y Aplicación Inicial.

Autor: Diego Ruiz Navarro

Número de Expediente: 06647908B

Tutor: Jorge Moratalla Collado

Para el análisis de aplicaciones, se ha decidido agregar los controles en ciertos grupos, cuando sea posible, para facilitar la cumplimentación del cuestionario, así como para reducir la necesidad de realizar acciones similares en diversas ocasiones.

De esta manera, podríamos tener un grupo de Gestión de Accesos y Usuarios, compuesto por los controles del 35 al 46; un grupo de Privacidad y Transparencia compuesto por los controles del 467al 58; y un grupo de Resiliencia y Protección de la Plataforma, compuesto por los controles del 59 al 68.

Cabe destacar, que en este documento los controles indicados actualmente no presentan la misma numeración, sino una que va del 1 al 34, por lo que para conocer qué control de esta selección corresponde con el control del cuestionario, habrá que sumar 34 al número que correspondiente al control de la selección.

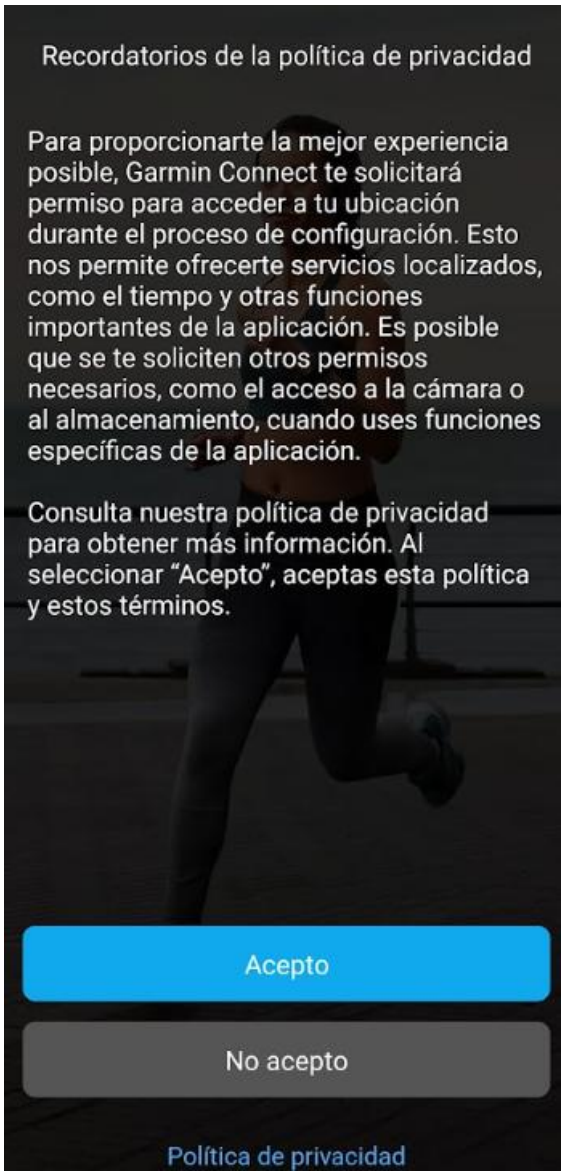
Por ello, a menos que el propio flujo de la aplicación promueva la revisión de un control determinado en un orden distinto al supuesto inicialmente, se seguirá el orden impuesto por dichos grupos.

Garmin Connect

Se ha instalado el archivo .apk de la aplicación para la versión 5.22.1 de la web "UpToDown".

Para comenzar, y dado que estamos ante la situación de que la aplicación se está analizando utilizando un entorno de virtualización como Android Studio, empleando un dispositivo Pixel 6 virtualizado, se puede confirmar que la aplicación no tiene en cuenta cuando se ejecuta en un entorno de pruebas o virtualizado, ni responde ante ello, por lo que se puede responder a la pregunta 34 negativamente. De igual manera, dado que el dispositivo virtualizado es antiguo, su versión del sistema operativo es igualmente antigua, permitiendo responder negativamente a la pregunta 31.

En el funcionamiento regular de la aplicación, lo primero que aparece en la inicialización inicial de la aplicación es la aceptación de la política de privacidad. Esto permite contestar preguntas del cuestionario mediante el análisis de la política de privacidad. Primeramente, se pueden contestar las preguntas 20 y 21 afirmativamente respecto a la existencia de una política de privacidad y de la solicitud del consentimiento al tratamiento de datos del usuario. Seguidamente se pueden contestar la pregunta 22 y la pregunta 23 respecto a la capacidad del usuario de revocar el consentimiento de tratamiento de sus datos y respecto a la mención de cómo se tratan los datos de telemetría, permitiendo responder ambas positivamente. A continuación, se puede contestar negativamente a la pregunta 18 respecto a la existencia de una guía para el borrado de datos, dado que no existe dicha guía. Finalmente, se puede contestar a las preguntas 7 y 8 afirmativamente puesto que, en un documento alterno al de la política de privacidad, se puede encontrar dicha información.



consentimiento del usuario. El usuario puede retirar su consentimiento en cualquier momento cambiando las preferencias de su cuenta o a través del enlace para cancelar la suscripción. Las

Datos personales que se procesan cuando el usuario utiliza servicios basados en lugares en tiempo real:

Si el usuario elige utilizar servicios basados en lugares, como información sobre el tiempo, en su aplicación o dispositivo, se procederá a recopilar la información de la ubicación física de su dispositivo o dispositivo móvil conectado con el fin de que Garmin o sus proveedores suministren al usuario dichos servicios basados en lugares.

FIN Y FUNDAMENTO JURÍDICO:

El fin de procesar la ubicación del dispositivo del usuario es suministrar los servicios basados en lugares que este desea utilizar. El fundamento jurídico para el tratamiento de estos datos con dicho fin es el interés legítimo del usuario.

Datos personales que se procesan al sincronizar el dispositivo de Garmin:

Al sincronizar el dispositivo directamente o a través de una aplicación de Garmin compatible, registramos datos relativos a la transmisión, como la dirección IP utilizada al realizar la sincronización, la fecha y la hora de la sincronización, registros de diagnóstico/bloqueo, la ubicación geográfica del dispositivo, información sobre el dispositivo, información sobre la red empleada para sincronizar (por ejemplo, Wi-Fi o móvil) y el nivel de batería del dispositivo.

FINES Y FUNDAMENTOS JURÍDICOS:

Procesamos esta información para ayudar a identificar y resolver errores o problemas de sincronización. El fundamento jurídico para el tratamiento de esta información con dicho fin es nuestro interés legítimo en resolver errores o problemas de sincronización y proporcionar asistencia técnica de calidad.

Supervisión y análisis

Recopilamos datos de los usuarios acerca del uso que hacen de nuestros productos, servicios, sitios web y aplicaciones. Los tipos de información analítica que se recopilan incluyen la fecha y la hora en las que se accede a nuestros servidores, la versión de software, la ubicación del dispositivo, la configuración de idioma, la información y los archivos que se descargan, el comportamiento del usuario (como las funciones utilizadas, la frecuencia de uso), el estado del dispositivo, el modelo de dispositivo, información sobre el hardware y el sistema operativo e información relacionada con el funcionamiento del producto, servicio, sitio web o aplicación. Garmin utiliza estos datos para mejorar la calidad, seguridad y funcionalidad de nuestros productos, servicios, sitios web o aplicaciones; para desarrollar y comercializar productos y funciones que se adapten mejor a los usuarios, y para ayudar a identificar y solucionar con la mayor rapidez posible los problemas de estabilidad y otros problemas de uso.

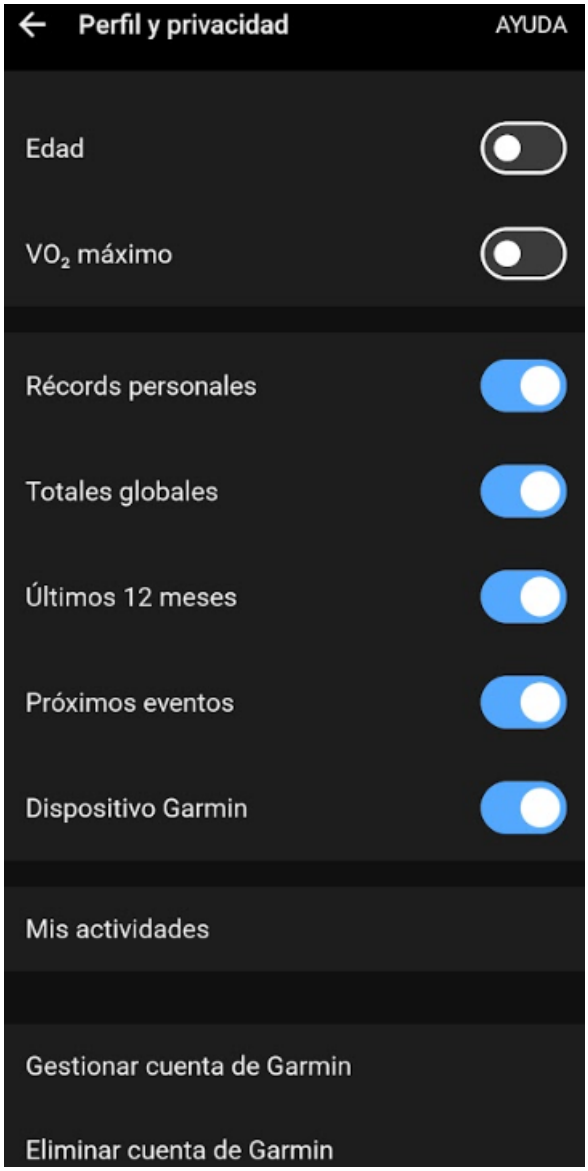
Garantía limitada para usuarios

ESTA GARANTÍA LIMITADA PROPORCIONA DERECHOS LEGALES ESPECÍFICOS AL USUARIO, QUIEN PODRÁ TENER OTROS DERECHOS LEGALES QUE PUEDEN VARIAR SEGÚN LA REGIÓN, EL PAÍS O LA PROVINCIA. GARMIN NO EXCLUYE, LIMITA NI SUSPENDE OTROS DERECHOS LEGALES QUE EL USUARIO PUEDA TENER EN VIRTUD DE LAS LEYES DE SU REGIÓN, PAÍS O PROVINCIA. PARA UNA COMPLETA COMPRENSIÓN DE SUS DERECHOS, EL USUARIO DEBERÁ CONSULTAR LAS LEYES VIGENTES EN SU REGIÓN, PAÍS O PROVINCIA.

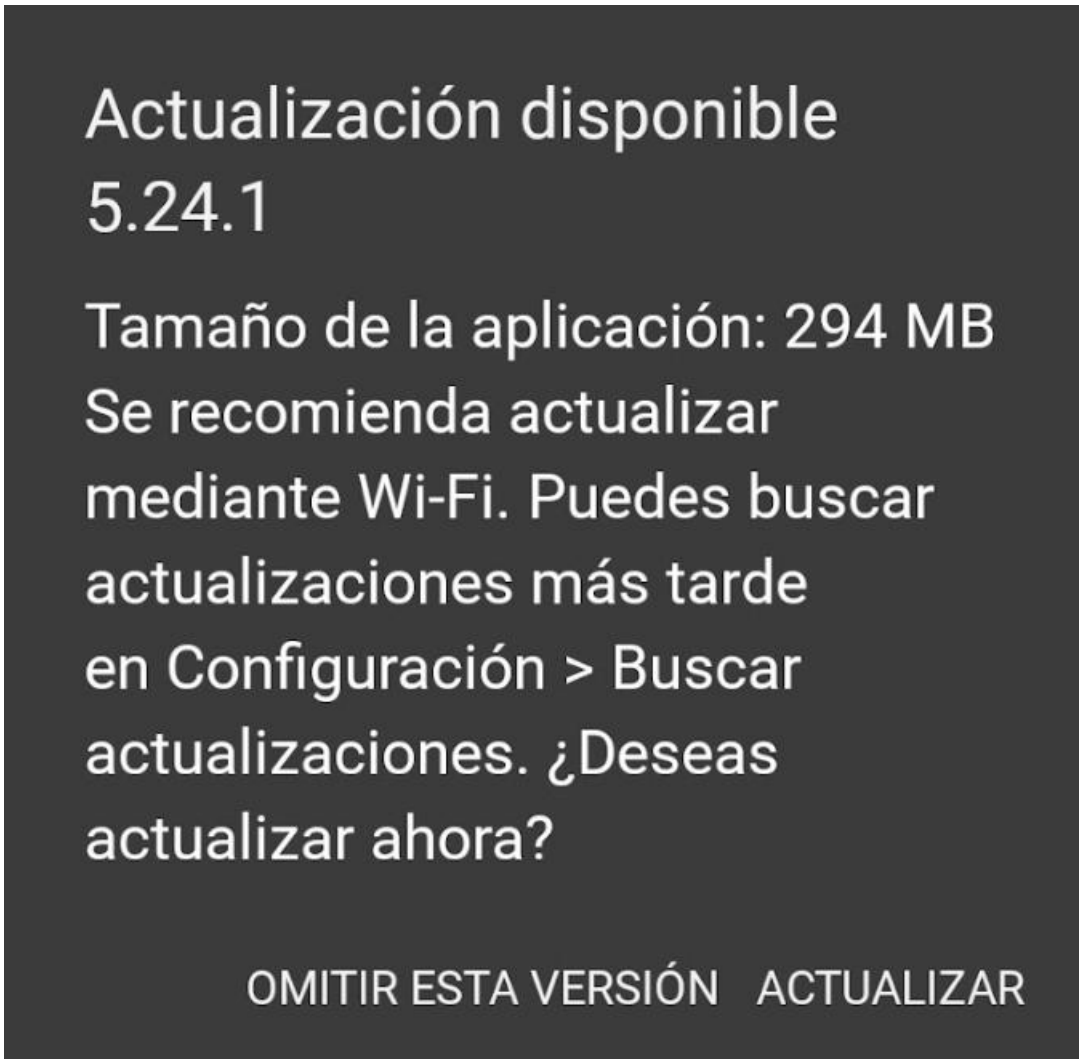
Una vez se ha completado esta primera parte, se procede con el seguimiento normal del cuestionario que, en este caso, coincide con el flujo de funcionamiento de la aplicación. Lo siguiente será proceder con las cuestiones relativas con la creación de credenciales y su gestión. En el proceso de creación de dichas credenciales, se puede observar si la aplicación utiliza una política de creación de contraseñas robusta. No se ha podido obtener una captura que certifique el siguiente hecho porque la aplicación restringe la capacidad de hacer cualquier tipo de captura de la pantalla, pero la propia aplicación limita la creación de contraseñas para que no puedan ser demasiado sencillas

obligando a que tengan una longitud mínima necesaria y contengan letras (mayúsculas y minúsculas), números y signos.

Yendo al menú accesible desde: más (tres puntos, …) -> Configuración -> Perfil y Privacidad -> Gestionar cuenta de Garmin, se puden gestionar las credenciales y otros datos de la cuenta de manera sencilla.



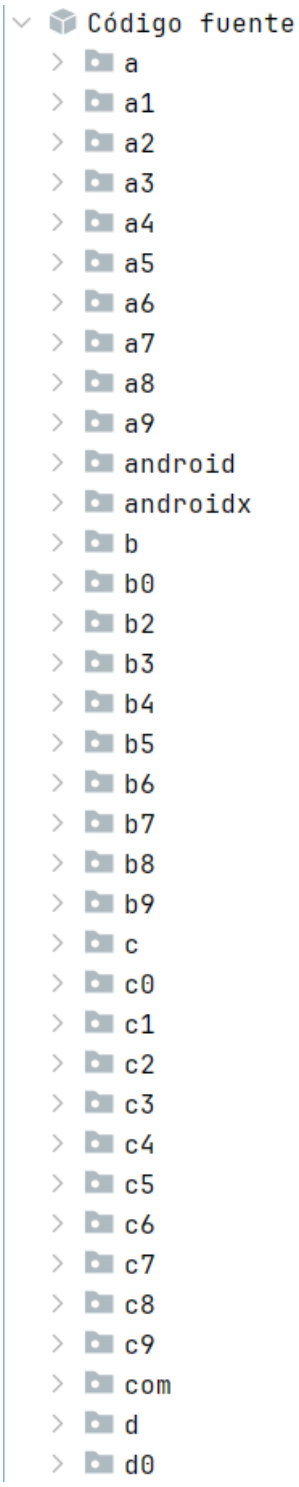
La aplicación, al inicializarse hace una búsqueda de las versiones actualizables que hay disponibles, por lo que el proceso de aplicación de actualizaciones es notablemente simple, se recibe el mensaje y simplemente presionas el botón que dice que se actualiza, por ello se puede contestar positivamente a las preguntas 3 y 5. La 4 se puede contestar así dado que, sin duda, el fabricante informa de forma clara de la disponibilidad de actualizaciones.



Respecto a la pregunta 4, no se ha encontrado ninguna manera de gestionar las actualizaciones automáticas en las preferencias de seguridad, por lo que se responderá negativamente a esta pregunta. De igual manera, la pregunta 6 se contestará negativamente puesto que la aplicación no avisa de los efectos que pueda tener la implementación de la actualización en el comportamiento usual de la aplicación. Finalmente, no se han encontrado instancias en las que, desde la aplicación, se haya emitido una orden obligatoria de actualización frente al descubrimiento de una vulnerabilidad crítica, por lo que la pregunta 32 se contestará negativamente.

A continuación, se empleará la herramienta JADX-GUI para analizar el código fuente de la aplicación. En primera instancia, se puede observar que el código está

ofuscado ya que todos aquellos datos que pudiese ser conflictivo mostrar, están ofuscados, permitiendo contestar positivamente a la pregunta 33.



A continuación se verificará que no existan secretos, claves, contraeñas, etc; hardcodeadas que puedan ser accesibles para cualquiera que pueda observar el código.

Esta verificación se realizará mediante la búsqueda de palabras como “key”, “password”, “secret”… Tras el análisis, no se han encontrado instancias de que este tipo de datos se encuentren hardcodeados. De hecho, no se han encontrado instancias de nada más que usos de servicios externos para la gestión de todos estos datos, salvo para la creación de secretos o claves, que son generadas directamente por el wearable. Esto permite contestar a la pregunta 9 positivamente.

Siguiendo con el cuestionario, lo siguiente q se ha de verificar es la utilización de las funciones criptográficas del dispositivo. Esto se traduce en la búsqueda de términos como “AES” o “RSA” y “MD5” o “DES” para definir los algoritmos criptográficos que se utilizan, así como buscar el término “AndroidKeyStore” para ver si el dispositivo utiliza el sistema nativo de gestión de claves de Android, acorde con las mejores práticas. Tras hacer esto, se obtiene como resultado que, aparentemente, utiliza algoritmos robustos y acordes con las mejores prácticas como “AES 256”, pero al mismo tiempo emplea algoritmos desfasados como “MD5”. En el caso de AES-256, se ha encontrado evidencia de que está definido para ser utilizado, pero no parece que haya instancias de su uso; esto se ha supuesto que es debido a que no se tiene acceso a dichas instancias. Teniendo todo esto en consideración, se ha decidido que se contestará como “Parcialmente” a la pregunta 9. Además, todo esto también permite responder de la misma forma a la pregunta 24 respecto a si el sistema evita que se filtren datos.

```java
public final void c(z zVar) {
    s8.f fVar = this.f8426b;
    String str = zVar.f8535a.i;
    a9.k kVar = a9.k.f259m;
    String strG = a.a.p(str).e("MD5").g();
    synchronized (fVar) {
        fVar.g();
        fVar.b();
        s8.f.z(strG);
        s8.d dVar = (s8.d) fVar.f9161t.get(strG);
        if (dVar == null) {
            return;
        }
        fVar.t(dVar);
        if (fVar.f9159r <= fVar.f9157p) {
            fVar.f9165y = false;
        }
    }
}
```

```
        a("TLS_DH_anon_WITH_AES_128_CBC_SHA256");
        a("TLS_DH_anon_WITH_AES_256_CBC_SHA256");
        a("TLS_RSA_WITH_CAMELLIA_256_CBC_SHA");
        a("TLS_DHE_DSS_WITH_CAMELLIA_256_CBC_SHA");
        a("TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA");
        a("TLS_PSK_WITH_RC4_128_SHA");
        a("TLS_PSK_WITH_3DES_EDE_CBC_SHA");
        a("TLS_PSK_WITH_AES_128_CBC_SHA");
        a("TLS_PSK_WITH_AES_256_CBC_SHA");
        a("TLS_RSA_WITH_SEED_CBC_SHA");
        g = a("TLS_RSA_WITH_AES_128_GCM_SHA256");
        h = a("TLS_RSA_WITH_AES_256_GCM_SHA384");
        a("TLS_DHE_RSA_WITH_AES_128_GCM_SHA256");
        a("TLS_DHE_RSA_WITH_AES_256_GCM_SHA384");
        a("TLS_DHE_DSS_WITH_AES_128_GCM_SHA256");
        a("TLS_DHE_DSS_WITH_AES_256_GCM_SHA384");
        a("TLS_DH_anon_WITH_AES_128_GCM_SHA256");
        a("TLS_DH_anon_WITH_AES_256_GCM_SHA384");
        a("TLS_EMPTY_RENEGOTIATION_INFO_SCSV");
        a("TLS_FALLBACK_SCSV");
        a("TLS_ECDH_ECDSA_WITH_NULL_SHA");
        a("TLS_ECDH_ECDSA_WITH_RC4_128_SHA");
        a("TLS_ECDH_ECDSA_WITH_3DES_EDE_CBC_SHA");
        a("TLS_ECDH_ECDSA_WITH_AES_128_CBC_SHA");
        a("TLS_ECDH_ECDSA_WITH_AES_256_CBC_SHA");
        a("TLS_ECDHE_ECDSA_WITH_NULL_SHA");
        a("TLS_ECDHE_ECDSA_WITH_RC4_128_SHA");
        a("TLS_ECDHE_ECDSA_WITH_3DES_EDE_CBC_SHA");
        a("TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA");
        a("TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA");
        a("TLS_ECDH_RSA_WITH_NULL_SHA");
        a("TLS_ECDH_RSA_WITH_RC4_128_SHA");
        a("TLS_ECDH_RSA_WITH_3DES_EDE_CBC_SHA");
        a("TLS_ECDH_RSA_WITH_AES_128_CBC_SHA");
        a("TLS_ECDH_RSA_WITH_AES_256_CBC_SHA");
        a("TLS_ECDHE_RSA_WITH_NULL_SHA");
        a("TLS_ECDHE_RSA_WITH_RC4_128_SHA");
        a("TLS_ECDHE_RSA_WITH_3DES_EDE_CBC_SHA");
```

Seguido a lo anterior, habrá que verificar si se utiliza el método de gestión de claves nativo para Android, Android Key Store, mediante la búsqueda del término “AndroidKeyStore” en el código fuente de la aplicación, para verificar si se utilizan los recursos criptográficos del dispositivo. El resultado de dicha búsqueda ha sido que no se ha encontrado ninguna evidencia de que se utilice dicho sistema, por lo que se contestará negativamente a la pregunta 11. Todo esto también permite responder de

igual manera a la pregunta 28 respecto a si se utilizan las medidas de gestión de claves de acuerdo a las mejores prácticas del sector.

Después, se debe verificar si se emplea un sistema que permita sustituir o actualizar los algoritmos y métodos criptográficos que se emplean. Para ello se buscará en el código si se utilizan los llamados proveedores dinámicos o si puede utilizar varios algoritmos distintos para encriptar los mismos datos. Tras la búsqueda en el código no se ha encontrado ninguna evidencia de que esto se haya utilizado en la aplicación, por lo que se debe contestar negativamente a la pregunta 12.

Luego, se verifica si el acceso a funciones de la aplicación mediante interfaces de red está limitado por la exigencia de un proceso de autenticación previo. Esto se verificará buscando en el código evidencias de que ocurra mediante la búsqueda del término “Authentication” o “HTTP”. Tras la búsqueda, se ha encontrado evidencia de que se emplea una cabecera llamada authorization para los servicios HTTP, lo cual confirma la verificación y permite responder a la pregunta 13 de forma positiva. Además, no se han encontrado evidencias de que estas interfaces de red, en específico las accesibles remotamente, aseguren la integridad de los datos, haciendo necesario contestar negativamente a la pregunta 15.

```
TrafficStats.setThreadStatsTag(32771);
HttpURLConnection httpURLConnectionC = cVar.c(urlA, str2);
try {
    try {
        httpURLConnectionC.setRequestMethod(ShareTarget.METHOD_POST);
        httpURLConnectionC.addRequestProperty("Authorization", "FIS_v2 " + str5);
        httpURLConnectionC.setDoOutput(true);
        v2.c.h(httpURLConnectionC);
        responseCode = httpURLConnectionC.getResponseCode();
        bVar2.d(responseCode);
    } catch (Throwable th) {
        th = th;
        httpURLConnection = httpURLConnectionC;
    }
} catch (IOException | AssertionError unused) {
    httpURLConnection = httpURLConnectionC;
}
if (responseCode >= 200 && responseCode < 300) {
    bVarF = v2.c.f(httpURLConnectionC);
    httpURLConnectionC.disconnect();
    TrafficStats.clearThreadStatsTag();
    str = null;
```

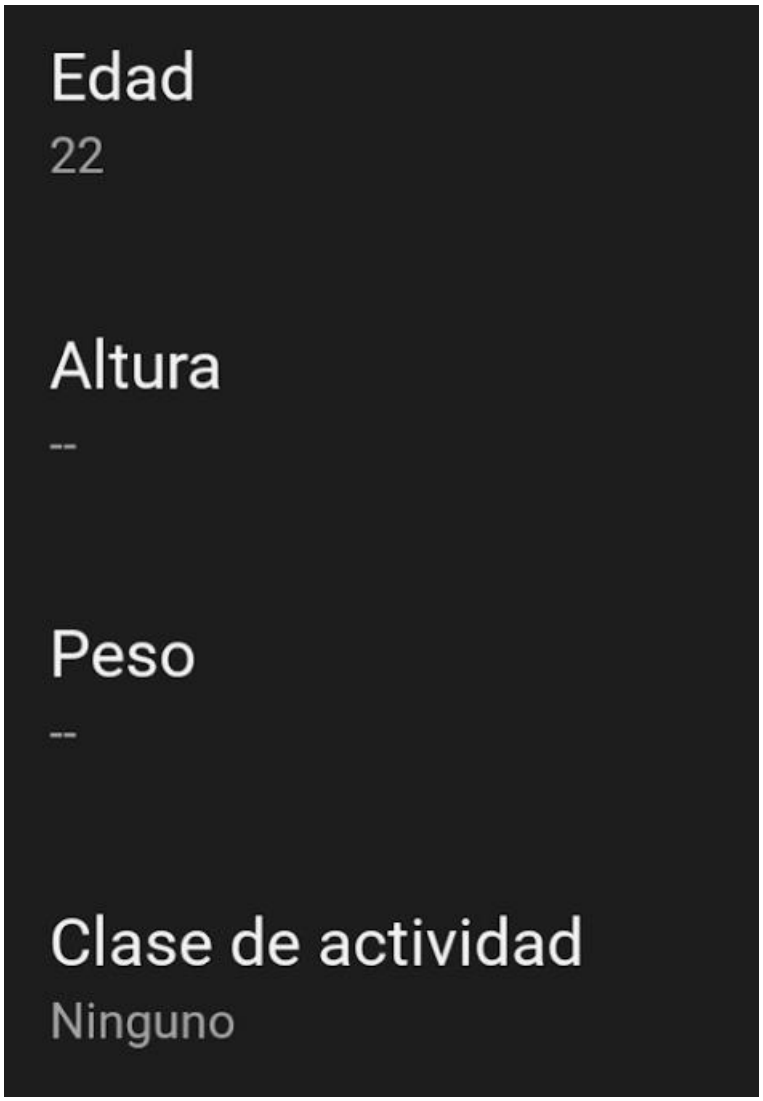
A continuación, se verifica si se pide la autenticación con permisos elevados para realizar cambios en configuraciones críticas. Analizando el código y buscando con palabras como “permit” no se ha encontrado ninguna evidencia de que esto sea así, por lo que se contestará negativamente a la pregunta 14.

Seguidamente, se verifica si, previamente a la autenticación, durante la inicialización, no se muestran datos técnicos sensibles. Esto se ha comprobado mediante la introducción de credenciales erróneas para la autenticación y la observación del mensaje que da el sistema. En este caso no se ha podido hacer captura de pantalla del mismo porque la aplicación no permite que se hagan capturas de pantalla de ningún tipo, pero se obtiene un mensaje genérico que permite contestar positivamente a la pregunta 16.

En cuanto a la pregunta 17, no se tiene acceso a esa información por lo que se debe puntuar como “No Aplica”.

Para la pregunta 19 se debe verificar si al borrar datos se emite un mensaje de que se está borrando un dato. Esto se verifica mediante el borrado de algún dato y la

visualización de la existencia o no de dicho mensaje. En este caso, tras la prueba, no se ha encontrado que se emita ningún mensaje de aviso. Esto permite contestar la pregunta negativamente.



Para la pregunta 25, habrá que verificar si la aplicación restringe las funciones críticas para ocasiones en los que el dispositivo acompañante tenga privilegios altos. Esto se realizará analizando el código buscando instancias en las que, tras el método isRooted(), se definan restricciones. En este caso, no se han encontrado evidencias que puedan respaldar esto, por lo que se responderá a esta pregunta negativamente.

Para la pregunta 26 se verificará si en el código hay instancias de detección de firmas o anti-debugging, buscando en el código palabras como “getPackageInfo” seguido con una detección de firmas, o “isDebuggerConnected()” para saber si se implementa un mecanismo de detección de integridad del código. El en análisis, se han

encontrado evidencias de anti-debugging y de detección de firmas, por lo que se contestará positivamente a la pregunta.

```
public static int c() {
    boolean zF = f();
    ?? r02 = zF;
    if (g()) {
        r02 = (zF ? 1 : 0) | 2;
    }
    return (Debug.isDebuggerConnected() || Debug.waitingForDebugger()) ? r02 | 4 : r02;
}
```

```
List<byte[]> listConvertToByteArrayList = convertToByteArrayList(packageManager.getPackageInfo(providerInfoResolveContentProvider.packageName, 64).signatures);
Collections.sort(listConvertToByteArrayList, sByteArrayComparator);
List<List<byte[]>> certificates = getCertificates(fontRequest, resources);
for (int i = 0; i < certificates.size(); i++) {
    ArrayList arrayList = new ArrayList(certificates.get(i));
    Collections.sort(arrayList, sByteArrayComparator);
    if (equalsByteArrayList(listConvertToByteArrayList, arrayList)) {
        return providerInfoResolveContentProvider;
    }
}
return null;
```

A continuación, para contestar a la pregunta 29, se verificará si se implementa Certificate Pinning para evitar un posible ataque MitM. Para ello, se buscará en el código la clase “Certificate Pinner” de la librería OkHttp o si se ha personalizado el X509TrustManager para aceptar ciertos certificado, cosas que indicarían el uso de este método. Tras esta búsqueda se ha encontrado evidencia del uso del X509TrustManager personalizado, por lo que se contestará positivamente a esta pregunta.

```
if (z9) {
    try {
        TrustManagerFactory trustManagerFactory = TrustManagerFactory.getInstance(TrustManagerFactory.getDefaultAlgorithm());
        trustManagerFactory.init((KeyStore) null);
        TrustManager[] trustManagers = trustManagerFactory.getTrustManagers();
        if (trustManagers.length == 1) {
            TrustManager trustManager = trustManagers[0];
            if (trustManager instanceof X509TrustManager) {
                X509TrustManager x509TrustManager = (X509TrustManager) trustManager;
                try {
                    y8.h hVar = y8.h.f11778a;
                    SSLContext sSLContextG = hVar.g();
                    sSLContextG.init(null, new TrustManager[]{x509TrustManager}, null);
                    this.f8517t = sSLContextG.getSocketFactory();
                    this.f8518u = hVar.c(x509TrustManager);
                } catch (GeneralSecurityException e5) {
                    throw r8.c.a("No System TLS", e5);
                }
            }
        }
        throw new IllegalStateException("Unexpected default trust managers:" + Arrays.toString(trustManagers));
    } catch (GeneralSecurityException e8) {
        throw r8.c.a("No System TLS", e8);
    }
```

Finalmente, la pregunta 30 pide verificar si, al mostrar contenido web, se deshabilitan los servicios de JavaScript y el acceso a archivos locales. Para esta verificación, se busca y accede a la variable get.Settings() de la clase WebView para ver

si las configuraciones setJavaScriptEnabled(), .setAllowFileAccess(), .setAllowFileAccessFromFileURLs() y .setAllowUniversalAccessFromFileURLs() están definidas en “False”. En este caso, solo se ha encontrado la primera configuración, y estaba definida en “True”, por lo que habrá que responder negativamente a esta pregunta.

1. ¿La aplicación impide el uso de contraseñas débiles o comunes mediante lista de exclusión o reglas de entropía? X SI • PM • NO • N/A 1/1

2. ¿La aplicación permite que el usuario pueda gestionar y modificar sus credenciales de forma sencilla? • SI • PM • NO • N/A 1/1

3. ¿El proceso de aplicación de actualizaciones es lo más simple posible para el usuario, pudiendo llegar a ser automático o requiriendo una mínima intervención? X SI • PM • NO • N/A 1/1

4. ¿El sistema permite al usuario configurar las actualizaciones automáticas a través de sus preferencias de seguridad? • SI • PM X NO • N/A 0/1

5. ¿El fabricante informa al usuario de forma clara sobre la disponibilidad de una actualización de seguridad y los riesgos que esta mitiga? X SI • PM • NO • N/A 1/1

6. ¿El sistema avisa explícitamente al usuario si una actualización va a interrumpir los servicios del dispositivo? • SI • PM X NO • N/A 0/1

7. ¿Se informa al usuario a través de la aplicación o documentación sobre el periodo de soporte de seguridad definido? X SI • PM • NO • N/A 1/1

8. ¿El usuario es informado sobre el periodo de soporte y el método de reemplazo hardware en caso de que el dispositivo tenga limitaciones para actualizarse?

X SI • PM • NO • N/A 1/1

9. ¿Se ha verificado que el código no contenga claves, tokens o contraseñas integrados directamente? X SI • PM • NO • N/A 1/1

10. ¿La aplicación utiliza las funciones criptográficas que están acorde con las mejores prácticas, siguiendo estándares robustos, para asegurar la comunicación cifrada? • SI X PM • NO • N/A 0.5/1

11. ¿Se ha verificado que se utilizan los recursos criptográficos que ofrece el dispositivo? • SI • PM X NO • N/A 0/1

12. ¿El software permite la actualización o sustitución de algoritmos criptográficos si fuese necesario? • SI • PM X NO • N/A 0/1

13. ¿Previo al acceso a sus funciones mediante interfaces de red, el wearable exige la autenticación? X SI • PM • NO • N/A 1/1

14. ¿La aplicación requiere la autenticación o un nivel administrativo de privilegios para permitir cambios en configuraciones críticas? • SI • PM X NO • N/A 0/1

15. ¿En interfaces de red accesibles remotamente se asegura la protección de parámetros críticos que se transporten por ellas utilizando cifrado? • SI • PM X NO • N/A 0/1

16. ¿Previo a la autenticación, durante la inicialización, se asegura que el dispositivo evita mostrar datos técnicos sensibles? X SI • PM • NO • N/A 1/1

17. ¿Se utilizado un Ciclo de desarrollo software seguro para compilar y firmar la aplicación móvil de gestión del wearable? • SI • PM • NO X N/A /1

18. ¿La aplicación móvil ofrece una guía para la eliminación de los datos del usuario? • SI • PM X NO • N/A 0/1

19. ¿La arquitectura wearable emite una confirmación explícita de que un proceso de borrado de datos se ha realizado satisfactoriamente? • SI • PM X NO • N/A 0/1

20. ¿La aplicación ofrece una política de privacidad donde se explique el tratamiento, finalidad y destinatarios de los datos personales del usuario, y que sea accesible fácilmente? X SI • PM • NO • N/A 1/1

21. ¿La aplicación solicita el consentimiento explícito del usuario para el tratamiento de datos? X SI • PM • NO • N/A 1/1

22. ¿La aplicación permite la revocación del consentimiento para el tratamiento de sus datos personales de manera sencilla? X SI • PM • NO • N/A 1/1

23. ¿Informa explícitamente la aplicación sobre la recolección de datos de telemetría y su uso? X SI • PM • NO • N/A 1/1

24. ¿La aplicación evita que se filtren datos sensibles? • SI X PM • NO • N/A 0.5/1

25. ¿La aplicación detecta si el móvil tiene privilegios altos y restringe funciones críticas? • SI • PM X NO • N/A 0/1

26. ¿La aplicación implementa mecanismos de detección de integridad del código? X SI • PM • NO • N/A 1/1

27. ¿Se asegura que todas las interacciones con otras apps ocurren de forma segura y autorizada? • SI • PM • NO X N/A /1

28. ¿La aplicación gestiona las claves de acuerdo a las mejores prácticas del sector? • SI • PM X NO • N/A 0/1

29. ¿La aplicación implementa Certificate Pinning para evitar ataques MitM? X SI • PM • NO • N/A 1/1

30. Cuando la aplicación muestra contenido web, ¿se desactivan los servicios de JavaScript y de archivos locales por defecto? • SI • PM X NO • N/A 0/1

31. ¿La aplicación impide su ejecución en versiones de sistema operativo obsoletas? • SI • PM X NO • N/A 0/1

32. ¿La aplicación implementa un sistema que obligue a realizar una actualización ante el descubrimiento de una vulnerabilidad crítica? • SI • PM • NO X N/A 0/1

33. ¿La aplicación implementa técnicas de ofuscación para dificultar el análisis del código? • SI • PM X NO • N/A 0/1

34. ¿La aplicación es capaz de detectar depuradores o entornos de instrumentación mientras está en funcionamiento? • SI • PM X NO • N/A 0/1

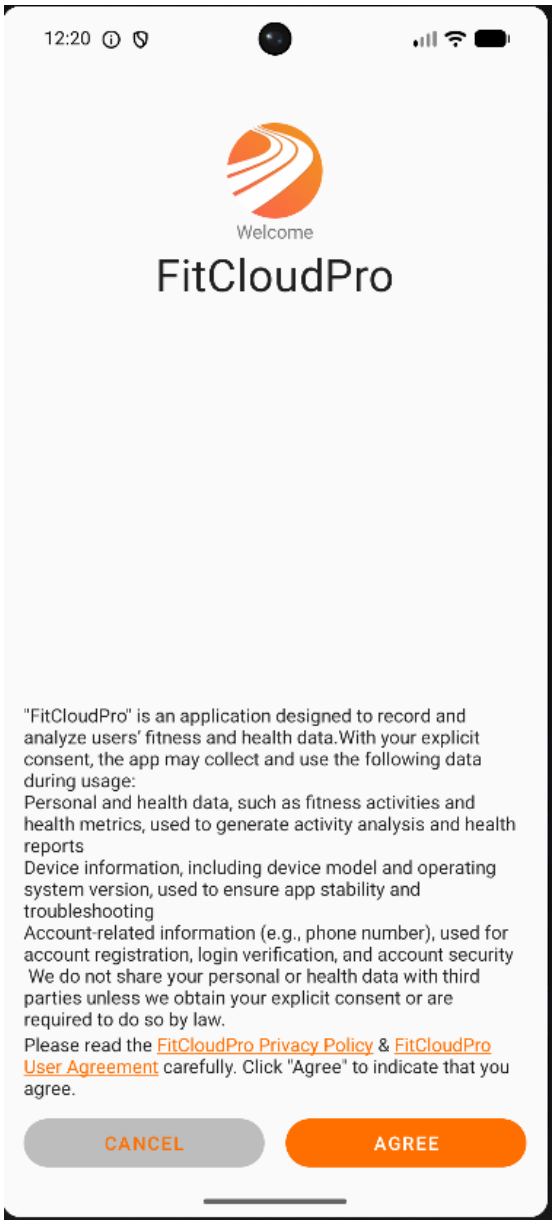
Ahora que se ha completado el cuestionario, se procede a hacer el conteo de la puntuación obtenida para, posteriormente, calcular el nivel de madurez. En este caso, siguiendo la fórmula mencionada en el documento principal, sale una puntuación del 50%, dando como resultado un Nivel de Madurez de Nivel 2, con una seguridad altamente mejorable, pero funcional.

FitCloudPro.

Se ha descargado el archivo .apk de la aplicación con la versión 2.5.8 desde la web de "UpToDown".

Al igual que en el anterior análisis, al estar trabajando en un entorno que simula un sistema operativo Android, y confirmar que la aplicación no parece responder antes este hecho, se puedo contestar negativamente la pregunta 34 del apartado de APP del cuestionario que se facilita en este documento.

Al inicializar la aplicación, lo primero que nos sale es el acuerdo a las políticas de privacidad y de consentimiento del usuario, esto implica que la aplicación pide expresamente el consentimiento del usuario para el tratamiento de sus datos, lo cual permite responder afirmativamente a la pregunta 21.



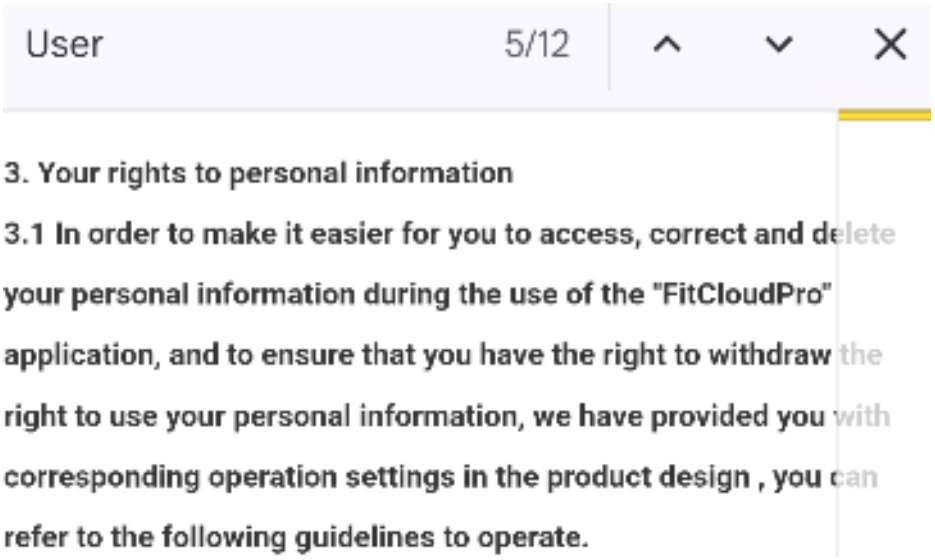
Al acceder a los documentos que se presentan, se permite acceder a información clave respecto al tratamiento de datos. Lo primero que se conoce en el documento de la privacidad, es cómo es el tratamiento, quién lo realiza, con quién lo comparte, etc. Esta información permite contestar la pregunta 20 con una respuesta afirmativa.

1. How we collect and use your personal information

1.1 When the app is in use or after exiting, you need to continue to access the motion sensor to obtain pedometer data, and connect to the network to complete data transmission. In order to provide sports guidance and health services, we need to collect and use your personal information as follows:

(a) Log in with your account and enjoy the "Tuobu" service. You need to register or log in your account to use the "Topbuy" service, so we will collect your account-related information, which may include your account number, nickname, avatar, height, weight, and gender.
(b) In order to manage your exercise data, we need to collect your device location, exercise track, exercise type (walking, running, etc.), exercise duration, number of steps, distance, calories and other exercise data. The location and trajectory are personal sensitive information, and the purpose of collecting such information is to record and count your daily movement data and trajectory.
(c) In order to improve the accuracy of your exercise data, some features require the collection of your height, weight and exercise settings (such as exercise goals, metric and imperial settings, etc.). Failure to provide this information will affect the accuracy of sports data calculations, but it will not affect the basic functionality of using the app.

Continuando leyendo la Política de Privacidad, se encuentra una guía de cómo acceder, corregir y borrar tus datos personales, así como de cómo revocar el permiso de tratamiento de tus datos, permitiendo contestar positivamente las preguntas 18 y 22.



User 5/12

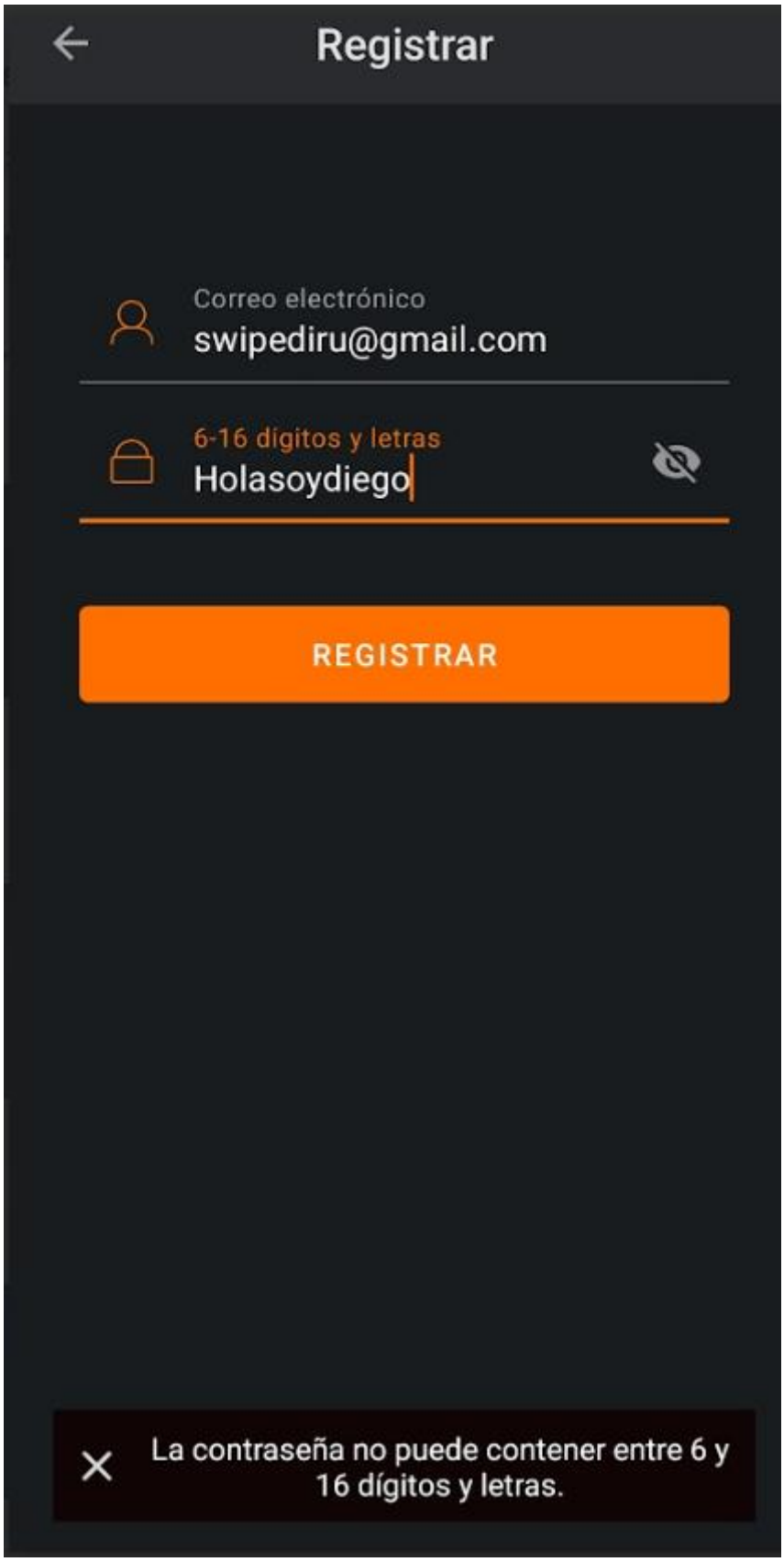
3. Your rights to personal information

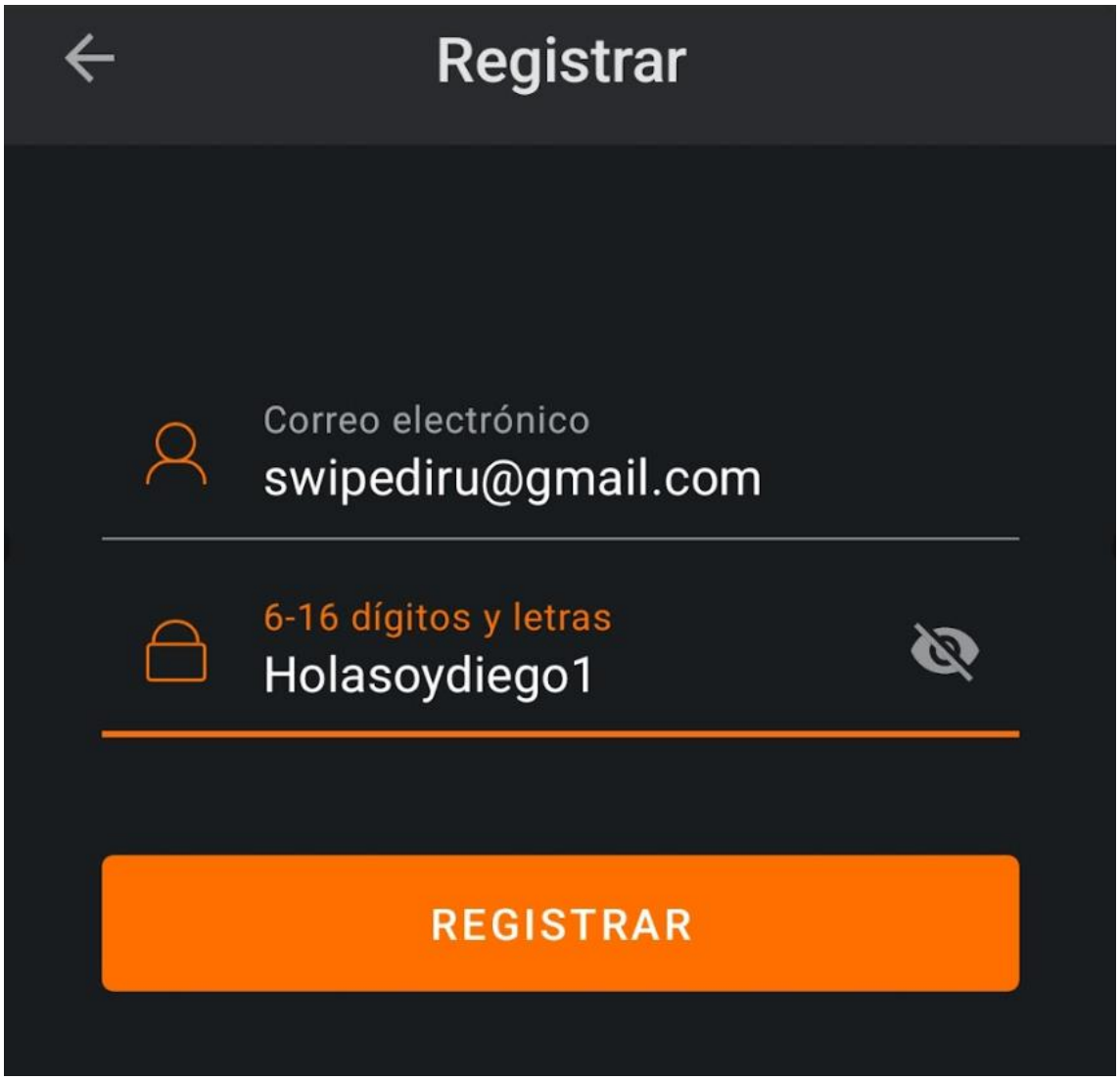
3.1 In order to make it easier for you to access, correct and delete your personal information during the use of the "FitCloudPro" application, and to ensure that you have the right to withdraw the right to use your personal information, we have provided you with corresponding operation settings in the product design , you can refer to the following guidelines to operate.

Finalmente, al leer la documentación disponible en la aplicación, no se ha encontrado mención al tratamiento de datos de telemetría. No obstante, esto no implica que se haga un tratamiento de estos datos pero que no se haya plasmado en la documentación o viceversa, por lo que se considera que lo más cauto es responder con un No Aplica.

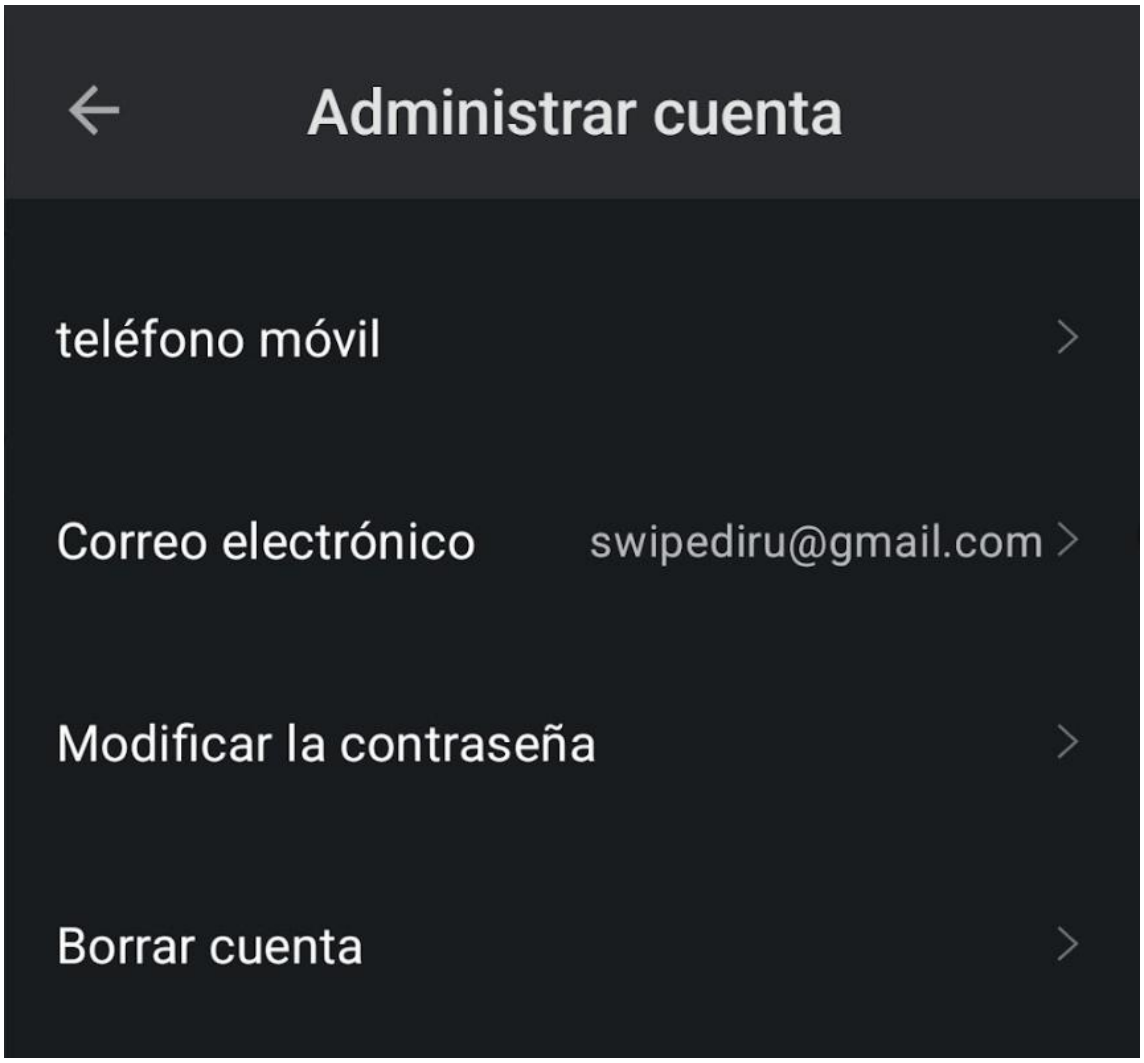
Lo siguiente que aparece en el flujo de inicialización de la aplicación es la creación de credenciales. Al no tener cuenta, se crea una nueva con credenciales nuevas de Gmail y contraseña. En cuanto a la contraseña, parece que la aplicación no permite que se utilicen contraseñas muy cortas, aunque tampoco muy largas, ni contraseñas que no contengan una cierta complejidad al tener números y letras en vez de solo letras. Por todo esto, se contestará a la pregunta 1 de forma intermedia.

FitCloudPro
Teléfono móvil / Correo electr...
Contraseña
¿Olvidaste tu contraseña?
INICIAR SESION
¿SIN CUENTA? CREAR


Registrar
Correo electrónico
swipediru@gmail.com
6-16 dígitos y letras
Holasoydiego
REGISTRAR
La contraseña no puede contener entre 6 y 16 dígitos y letras.



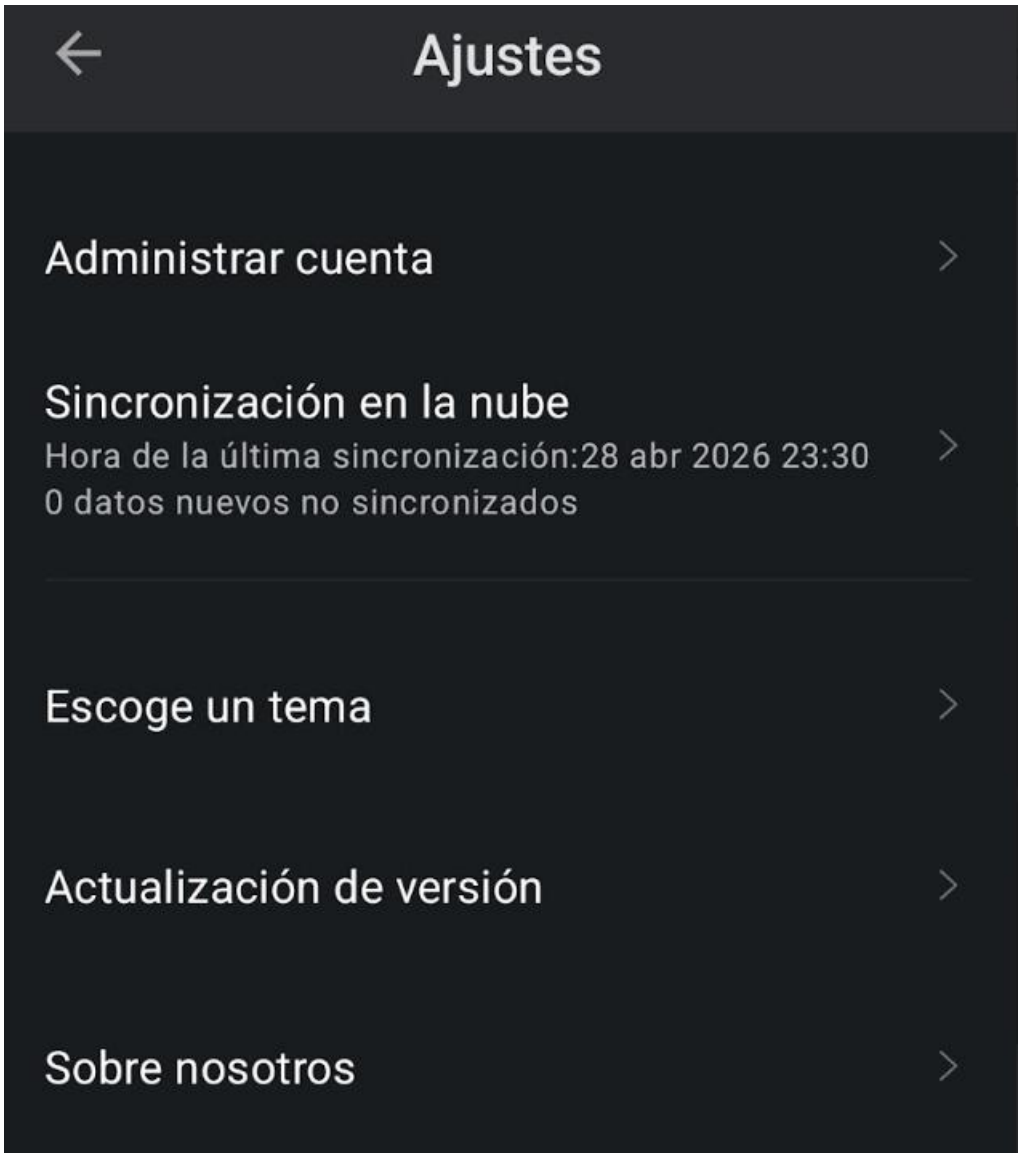
Navegando al menú Yo -> configuración -> gestión de cuenta, se pueden gestionar las credenciales de la cuenta de manera simple, permitiendo modificarlas e incluso borrar la cuenta. Esto permite contestar positivamente la pregunta 2.



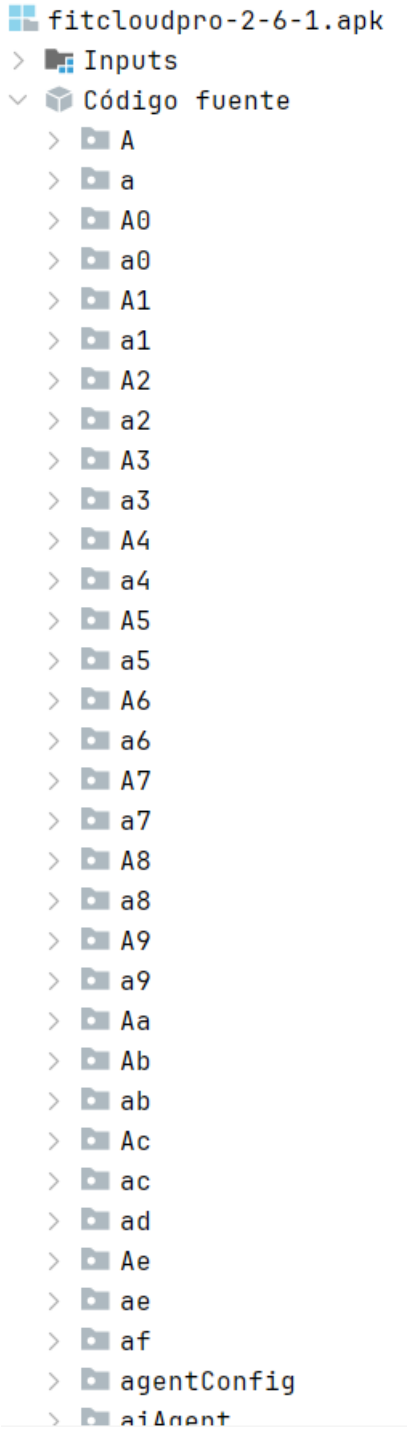
En lo relativo a información sobre los periodos de soporte de seguridad y hardware, así como al respecto del método de reemplazo hardware, en la documentación aportada por la aplicación no se incluye ninguna mención en estos respectos, por lo que se contestará negativamente a las preguntas 7 y 8.

Continuando con el proceso de análisis, el siguiente punto a examinar son las actualizaciones. Al iniciar la aplicación, con una versión más antigua que la actual, la aplicación no parece buscar de forma autónoma y automática nuevas actualizaciones. A pesar de esto, descargándola desde la “Play Store” de Google las aplicaciones suelen actualizarse automáticamente cuando tienen una nueva versión disponible. De igual forma, si se quiere hacer un chequeo de la disponibilidad de una nueva actualización,

simplemente requiere ir a Yo -> Configuración, y podrás buscar una actualización y aplicarla en el botón “Actualización de versión”. Todo lo mencionado permite responder a las preguntas de la 3 a la 6 de la siguiente manera: La 3 se responderá positivamente, como es evidente con lo anteriormente mencionado; la 4 se contestará negativamente puesto que no hay ningún menú en la aplicación en el que se permita al usuario gestionar las opciones de actualización de ningún modo; la 5 se responderá negativamente puesto que no ha quedado patente que el sistema avise de ninguna manera si hay actualizaciones disponibles y no se notifica en la Play Store de los bugs y arreglos que trae consigo cada actualización implementada; por último, la 6 se contestará negativamente puesto que, como se ha comentado, el sistema no da ningún aviso respecto a la disponibilidad de una actualización, incluyendo información adicional de su efecto en el funcionamiento regular de la aplicación mientras se aplica la actualización. De igual forma, se puede contestar la pregunta 32 negativamente, puesto que el sistema no emplea ningún tipo de sistema de gestión automática de actualizaciones por su cuenta, imposibilitando la actualización forzosa de la aplicación.


Ajustes
Administrar cuenta
Sincronización en la nube
Hora de la última sincronización:28 abr 2026 23:30
0 datos nuevos no sincronizados
Escoge un tema
Actualización de versión
Sobre nosotros

El siguiente control que propone el cuestionario es verificar la ausencia de claves criptográficas o cualquier tipo de credencial en el código. Esto requiere introducir el código del .apk en un programa que permita leerlo, lo cual posibilita contestar a otras cuestiones. Analizando el código, lo primero que se observa es que este está ofuscado dado que todas sus clases tienen nombres que son letras y/o números. Esto permite contestar a la pregunta 33 de forma positiva.



Después, se puede observar, mediante un análisis de palabras clave como “key”, “password” o “secret”, si hay contraseñas hard-codeadas. Tras el análisis, no se ha encontrado nada que pueda indicar este tipo de error en el código, por lo que se procede a contestar positivamente a la pregunta 9.

A continuación, y a pesar de que en la play store te avisa de que los datos no son encriptados, se comprobarán los algoritmos de cifrado que se utilizan haciendo una búsqueda en el código fuente con términos como “AES”, “DES”, “MD5”. Tras la búsqueda, se ha obtenido que los algoritmos utilizados están de acuerdo con las mejores prácticas actuales, habiendo menciones a algoritmos débiles pero que no se utilizan. Esto permite contestar a la pregunta 10 positivamente.

```
private static byte[] b(String str, String str2, byte[] bArr) throws Exception {
    if (TextUtils.isEmpty(str2) || TextUtils.isEmpty(str)) {
        return null;
    }
    SecretKeySpec secretKeySpec = new SecretKeySpec(str2.getBytes("ASCII"), "AES");
    Cipher cipher = Cipher.getInstance("AES/CBC/NoPadding");
    cipher.init(2, secretKeySpec, new IvParameterSpec(str.getBytes()));
    return cipher.doFinal(bArr);
}
```

```
static {
    HashMap map = new HashMap();
    map.put(createKey("SHA-256", 32, 16, 67, 10), new DefaultXMSSOid(1, "XMSS_SHA2_10_256"));
    map.put(createKey("SHA-256", 32, 16, 67, 16), new DefaultXMSSOid(2, "XMSS_SHA2_16_256"));
    map.put(createKey("SHA-256", 32, 16, 67, 20), new DefaultXMSSOid(3, "XMSS_SHA2_20_256"));
    map.put(createKey("SHA-512", 64, 16, 131, 10), new DefaultXMSSOid(4, "XMSS_SHA2_10_512"));
    map.put(createKey("SHA-512", 64, 16, 131, 16), new DefaultXMSSOid(5, "XMSS_SHA2_16_512"));
    map.put(createKey("SHA-512", 64, 16, 131, 20), new DefaultXMSSOid(6, "XMSS_SHA2_20_512"));
    map.put(createKey("SHAKE128", 32, 16, 67, 10), new DefaultXMSSOid(7, "XMSS_SHAKE_10_256"));
    map.put(createKey("SHAKE128", 32, 16, 67, 16), new DefaultXMSSOid(8, "XMSS_SHAKE_16_256"));
    map.put(createKey("SHAKE128", 32, 16, 67, 20), new DefaultXMSSOid(9, "XMSS_SHAKE_20_256"));
    map.put(createKey("SHAKE256", 64, 16, 131, 10), new DefaultXMSSOid(10, "XMSS_SHAKE_10_512"));
    map.put(createKey("SHAKE256", 64, 16, 131, 16), new DefaultXMSSOid(11, "XMSS_SHAKE_16_512"));
    map.put(createKey("SHAKE256", 64, 16, 131, 20), new DefaultXMSSOid(12, "XMSS_SHAKE_20_512"));
    oidLookupTable = Collections.unmodifiableMap(map);
}
```

Lo siguiente será comprobar si se utilizan los recursos criptográficos proveídos por el dispositivo son utilizados. Esto es traduce en el uso correcto de un chip TEE o un Secure Enclave, intrínsecamente conectados con el uso de la Android KeyStore. Por ello, se buscará en el código fuente cualquier mención de “AndroidKeyStore” para definir si se utiliza o no. Tras la búsqueda, se ha encontrado mención de la aplicación solicitando servicio a la AndroidKeyStore, pero no se han encontrado evidencias de que se maneje la limitación para que la información no sea capaz de salir del hardware. Por todo esto es que se ha decidido contestar a la pregunta 11 negativamente.

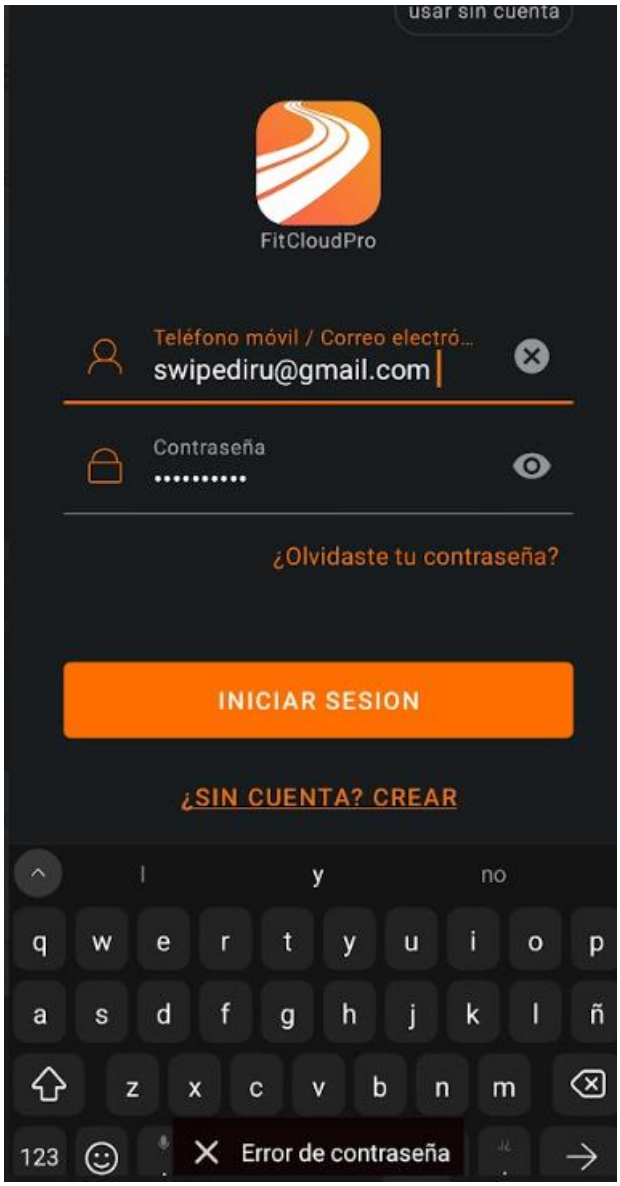
El siguiente paso sería analizar el código en busca de evidencias de que se utilicen métodos que permitan un dinamismo en el uso de algoritmos criptográficos, pero tras las anteriores búsquedas se ha comprobado que los algoritmos que están definidos en el código no son intercambiables, por lo que la pregunta 12 se contestará negativamente.

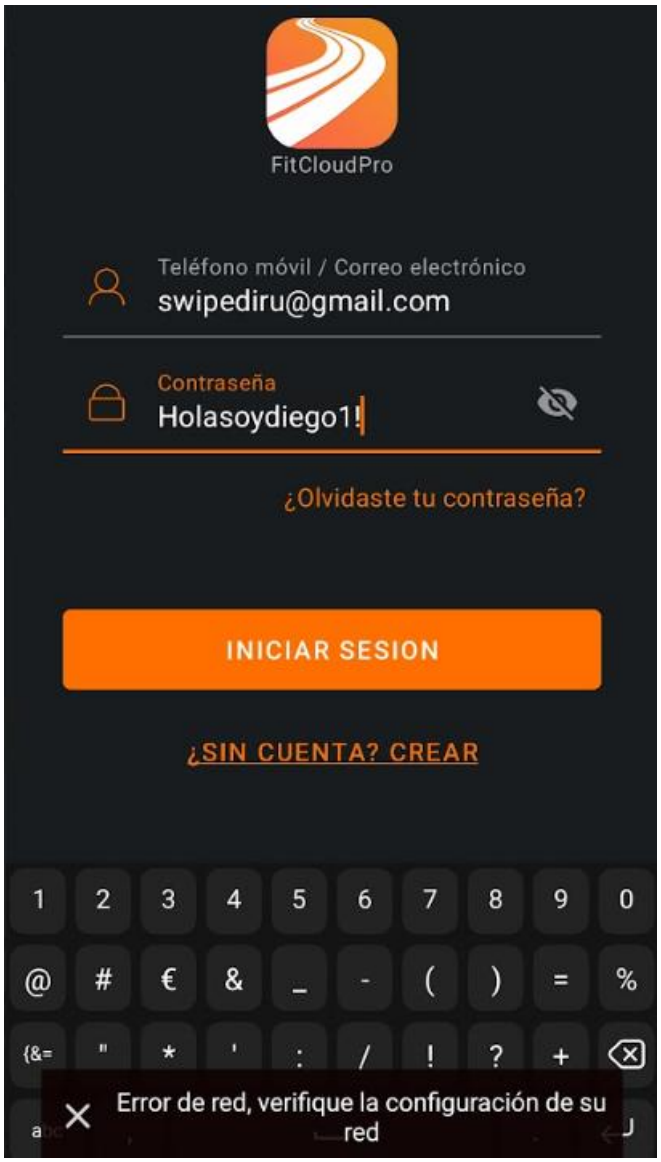
De igual forma, al analizar el código en busca de líneas que indiquen que la aplicación pide una autenticación del usuario antes de permitir el acceso a las funciones a través de una interfaz de red, pero no se ha encontrado evidencia de esto; permitiendo contestar negativamente a la pregunta 13. Lo mismo se puede decir de la pregunta 14, puesto que la búsqueda de autenticación para la pregunta 13 ha permitido verificar si se pide autenticación en cambios de configuración, dando un resultado negativo. Pasa lo mismo para la pregunta 15, no se encuentra ninguna configuración específica para las interfaces de red del dispositivo, por lo que esta pregunta se contestará negativamente también.

Todo lo anteriormente mencionado respecto a el uso de criptografía y la gestión de la autenticación en determinadas situaciones, permite contestar la pregunta 24 con cierta seguridad. En este caso, dado que no se aplican restricciones a la autenticación en casos específicos, ni parece que se emplee ningún tipo de encriptación de datos en la aplicación, se procede a contestar negativamente a esta pregunta.

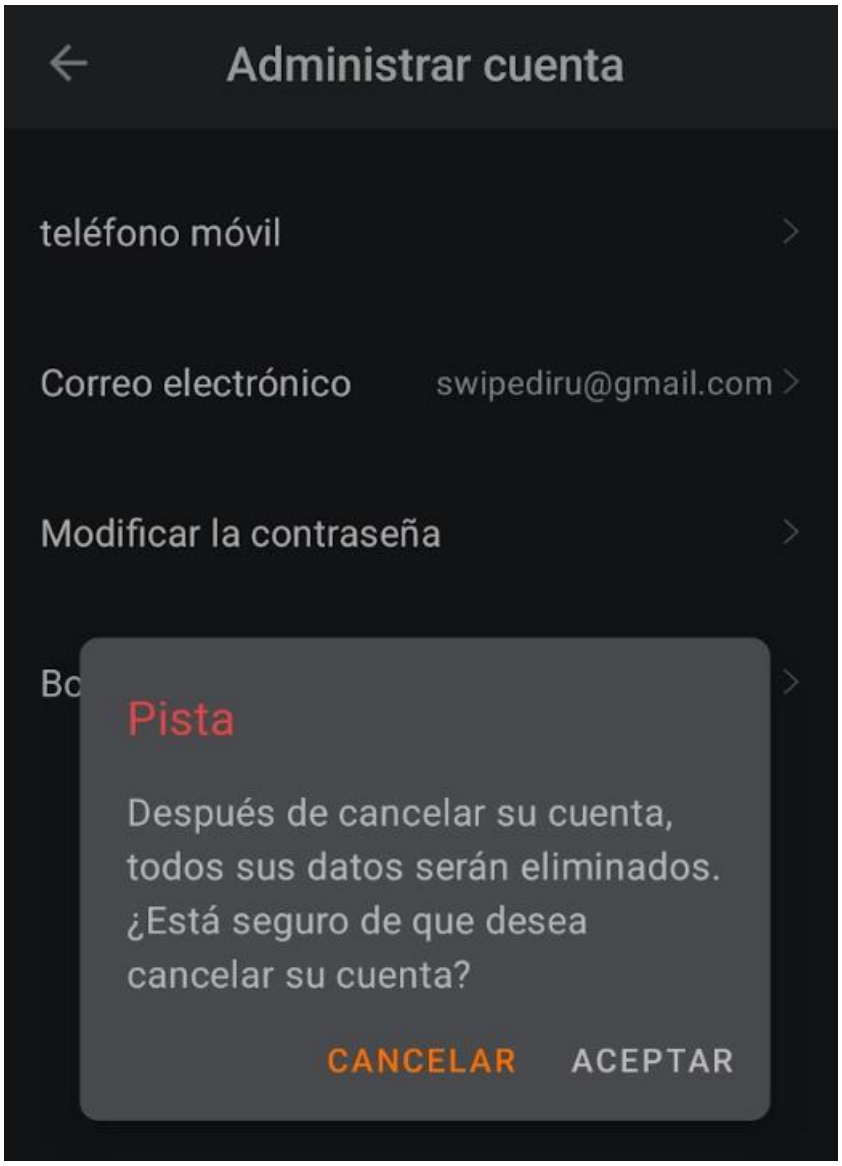
La siguiente comprobación se ha realizado respecto a los mensajes que emite la aplicación durante la inicialización del dispositivo, antes de que el usuario se haya autenticado. Se ha verificado que los mensajes dados al usuario son genéricos y no incluyen datos sensibles de ningún tipo, permitiendo contestar positivamente a la pregunta 16.

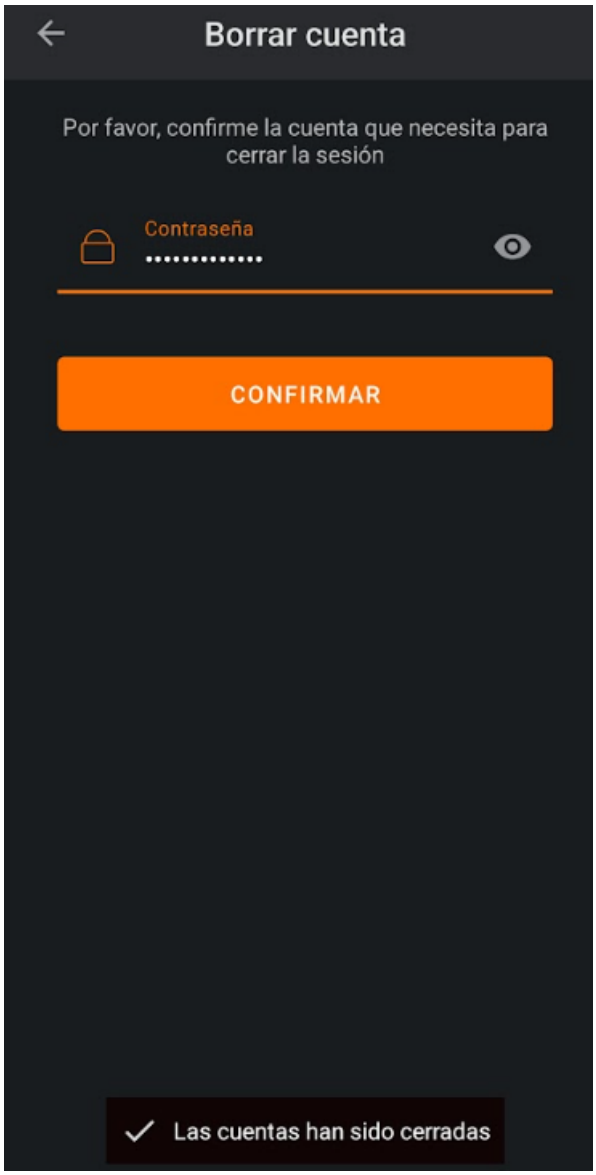
usar sin cuenta
FitCloudPro
Teléfono móvil / Correo electrónico
holaprobando@prueva.com
Contraseña
¿Olvidaste tu contraseña?
INICIAR SESION
¿SIN CUENTA? CREAR
Este usuario no existe


usar sin cuenta
FitCloudPro
Teléfono móvil / Correo electró...
swipediru@gmail.com
Contraseña
¿Olvidaste tu contraseña?
INICIAR SESION
¿SIN CUENTA? CREAR
Error de contraseña



A continuación, se pide verificar que el sistema emite una alerta o notificación cuando se borran datos en la aplicación. Esto se comprueba en el menú Yo -> Configuración -> Administrar Cuenta -> Borrar Cuenta, dando un resultado afirmativo, permitiendo contestar a la pregunta 19 afirmativamente.


Administrar cuenta
teléfono móvil
Correo electrónico
swipediru@gmail.com
Modificar la contraseña
Bo
Pista
Después de cancelar su cuenta, todos sus datos serán eliminados. ¿Está seguro de que desea cancelar su cuenta?
CANCELAR
ACEPTAR



Para las preguntas 25 y 26, hay que analizar el código fuente en busca de evidencias que demuestren que se verifica si el dispositivo acompañante utiliza permisos root y, en caso afirmativo, restringe las acciones que puede realizar; así como evidencias de que se utiliza un mecanismo de monitorización de integridad del código. En este caso, no se ha encontrado ninguna evidencia que refuerce ninguna de estas cuestiones por lo que ambas preguntas se contestarán negativamente. Además, la pregunta 27 se contestará como No aplica, puesto que no se tiene acceso a ninguna otra aplicación que pueda ser utilizada con esta aplicación ni al grado de seguridad de la interacción entre estas.

Para continuar, la pregunta 28 se puede contestar negativamente basándose en la información anteriormente recabada respecto a las medidas criptográficas y de almacenamiento de las mismas. Posteriormente, la pregunta 29 se contestará mediante un análisis del código fuente en busca, principalmente, del uso de la clase "CertificatePinner" de la librería OkHttp. El análisis permitió encontrar el uso de dicha clase en múltiples instancias, llegando a utilizarla y no solo a prepararla, permitiendo contestar a esta pregunta positivamente.

```
public final Builder certificatePinner(CertificatePinner certificatePinner) {
    AbstractC2199i.f(certificatePinner, "certificatePinner");
    if (!certificatePinner.equals(this.certificatePinner)) {
        this.routeDatabase = null;
    }
```

Para la pregunta 30, en este caso se tiene que contestar que No aplica, puesto que esta aplicación no muestra ningún tipo de contenido web.

Finalmente, para la pregunta 31 ya se tiene una respuesta negativa puesto que las pruebas realizadas sobre la aplicación se han hecho a través de Android Studio, a través de un dispositivo Pixel 6 simulado con una versión del sistema operativo desfasada.

1. ¿La aplicación impide el uso de contraseñas débiles o comunes mediante lista de exclusión o reglas de entropía? • SI X PM • NO • N/A 0.5/1

2. ¿La aplicación permite que el usuario pueda gestionar y modificar sus credenciales de forma sencilla? X SI • PM • NO • N/A 1/1

3. ¿El proceso de aplicación de actualizaciones es lo más simple posible para el usuario, pudiendo llegar a ser automático o requiriendo una mínima intervención? X SI • PM • NO • N/A 0/1

4. ¿El sistema permite al usuario configurar las actualizaciones automáticas a través de sus preferencias de seguridad? • SI • PM X NO • N/A 0/1

5. ¿El fabricante informa al usuario de forma clara sobre la disponibilidad de una actualización de seguridad y los riesgos que esta mitiga? • SI • PM X NO • N/A 0/1

6. ¿El sistema avisa explícitamente al usuario si una actualización va a interrumpir los servicios del dispositivo? • SI • PM X NO • N/A 0/1

7. ¿Se informa al usuario a través de la aplicación o documentación sobre el periodo de soporte de seguridad definido? • SI • PM X NO • N/A 0/1

8. ¿El usuario es informado sobre el periodo de soporte y el método de reemplazo hardware en caso de que el dispositivo tenga limitaciones para actualizarse? • SI • PM X NO • N/A 0/1

9. ¿Se ha verificado que el código no contenga claves, tokens o contraseñas integrados directamente? X SI • PM • NO • N/A 1/1

10. ¿La aplicación utiliza las funciones criptográficas que están acorde con las mejores prácticas, siguiendo estándares robustos, para asegurar la comunicación cifrada? X SI • PM • NO • N/A 1/1

11. ¿Se ha verificado que se utilizan los recursos criptográficos que ofrece el dispositivo? • SI • PM X NO • N/A 0/1

12. ¿El software permite la actualización o sustitución de algoritmos criptográficos si fuese necesario? • SI • PM X NO • N/A 0/1

13. ¿Previo al acceso a sus funciones mediante interfaces de red, el wearable exige la autenticación? • SI • PM X NO • N/A 0/1

14. ¿La aplicación requiere la autenticación o un nivel administrativo de privilegios para permitir cambios en configuraciones críticas? • SI • PM X NO • N/A 0/1

15. ¿En interfaces de red accesibles remotamente se asegura la protección de parámetros críticos que se transporten por ellas utilizando cifrado? • SI • PM X NO • N/A 0/1

16. ¿Previo a la autenticación, durante la inicialización, se asegura que el dispositivo evita mostrar datos técnicos sensibles? X SI • PM • NO • N/A 1/1

17. ¿Se utilizado un Ciclo de desarrollo software seguro para compilar y firmar la aplicación móvil de gestión del wearable? • SI • PM • NO X N/A /1

18. ¿La aplicación móvil ofrece una guía para la eliminación de los datos del usuario? X SI • PM • NO • N/A 1/1

19. ¿La arquitectura wearable emite una confirmación explícita de que un proceso de borrado de datos se ha realizado satisfactoriamente? X SI • PM • NO • N/A 1/1

20. ¿La aplicación ofrece una política de privacidad donde se explique el tratamiento, finalidad y destinatarios de los datos personales del usuario, y que sea accesible fácilmente? X SI • PM • NO • N/A 1/1

21. ¿La aplicación solicita el consentimiento explícito del usuario para el tratamiento de datos? X SI • PM • NO • N/A 1/1

22. ¿La aplicación permite la revocación del consentimiento para el tratamiento de sus datos personales de manera sencilla? X SI • PM • NO • N/A 1/1

23. ¿Informa explícitamente la aplicación sobre la recolección de datos de telemetría y su uso? • SI • PM • NO X N/A /1

24. ¿La aplicación evita que se filtren datos sensibles? • SI • PM X NO • N/A 0/1

25. ¿La aplicación detecta si el móvil tiene privilegios altos y restringe funciones críticas? • SI • PM X NO • N/A 0/1

26. ¿La aplicación implementa mecanismos de detección de integridad del código? • SI • PM X NO • N/A 0/1

27. ¿Se asegura que todas las interacciones con otras apps ocurren de forma segura y autorizada? • SI • PM • NO X N/A /1

28. ¿La aplicación gestiona las claves de acuerdo a las mejores prácticas del sector? • SI • PM • NO • N/A /1

29. ¿La aplicación implementa Certificate Pinning para evitar ataques MitM? X SI • PM • NO • N/A 1/1

30. Cuando la aplicación muestra contenido web, ¿se desactivan los servicios de JavaScript y de archivos locales por defecto? • SI • PM • NO X N/A /1

31. ¿La aplicación impide su ejecución en versiones de sistema operativo obsoletas? • SI • PM X NO • N/A 0/1

32. ¿La aplicación implementa un sistema que obligue a realizar una actualización ante el descubrimiento de una vulnerabilidad crítica? • SI • PM X NO • N/A 0/1

33. ¿La aplicación implementa técnicas de ofuscación para dificultar el análisis del código? X SI • PM • NO • N/A 1/1

34. ¿La aplicación es capaz de detectar depuradores o entornos de instrumentación mientras está en funcionamiento? • SI • PM X NO • N/A 0/1

Ahora que se ha completado el cuestionario, se procede a hacer el conteo de la puntuación obtenida para, posteriormente, calcular el nivel de madurez. En este caso, siguiendo la fórmula mencionada en el documento principal, sale una puntuación de 38,3%, lo cual ya indica que la Aplicación analizada tiene un nivel de Madurez de Nivel 1, el más bajo posible.